SECURITY & COMPLIANCE · RECRUITMENT SAAS

Enterprise-grade security, configured by each organisation

Single sign-on, multi-factor authentication, password and lockout policies, network restrictions and audit logging. Each control is switched on per tenant and tuned by the organisation's own administrators, with no code changes.

Sreeram Goalla · Product Owner & Business Analyst · ReadyTech

Introduction

Organisations that hold candidate and placement data have to show who can get in, from where, and what they did once inside. The recruitment platform answers that with a set of controls that are off by default and switched on per tenant. Once a control is on, the organisation's own administrators configure it under **Admin → Security Settings**.



Strong identity

Sign in through your organisation's identity provider (SAML SSO), or with a password plus a one-time code from an authenticator app.



Policy you control

Password length and complexity, lockout thresholds, session timeouts and confirmation-link expiry are all set by the organisation's own admins.



Network & file safety

Restrict access to approved IP ranges, scan every upload for viruses, and send email through your own mail gateway.



Accountability

User activity logs, sign-in tracking and an audit trail for bulk candidate exports show who did what, and when.

My role

I was the **product owner and business analyst** for this programme (Nov 2021 – Sep 2022), from turning customers' security requirements into a roadmap through to acceptance and release. A team of four engineers built it; I owned what was built, in what order, and how we knew it worked.

PRODUCT MANAGER

Turned a compliance requirement into a sequenced, opt-in roadmap

- Framed the problem: customers bound by government and enterprise security frameworks needed controls the product didn't yet have.
- Sequenced 12 controls by customer risk: SSO, session timeout and lockout first (Nov 2021), then the logon banner and MFA (Dec), then password policy (early 2022).
- Chose per-customer opt-in with admin-configurable settings, so each customer adopts at its own pace and nothing changes for anyone else.
- Iterated after launch on customer feedback, adding an admin MFA reset and a configurable password length.

What I produced: Product roadmap, Epics, Release documentation

BUSINESS ANALYST

Specified each control so it was buildable and testable

- Broke each control into user stories with explicit business rules: thresholds, durations, defaults and who can change them.
- Defined secure defaults with admin-selectable options, e.g. lockout after 3, 5, 7 or 10 attempts, and session timeouts from 15 minutes to 4 hours.
- Designed the admin experience: one Security Settings area, where each control appears only once it is switched on.
- Pinned down the edge cases: timed vs manual unlock, confirmation-link expiry on resend, and admin-only download of infected files.

What I produced: User stories, Business rules, Admin journey

QUALITY & TESTING

Defined how we would know each control worked

- Wrote acceptance criteria and test scenarios for every control, including boundary and negative cases.
- For example: the 5th failed attempt locks the account, and it unlocks after 15 minutes; a second sign-in ends the first session; a request from outside the allowed IP ranges gets a 403; a breached password is rejected.
- Coordinated UAT and release validation with stakeholders before each control went live.
- Validated that controls stayed off, with no behaviour change, for customers who hadn't opted in.

What I produced: Acceptance criteria, Test scenarios, UAT

12
security controls delivered

7
admin settings, all self-service

10
months, Nov 2021 – Sep 2022

Identity & access

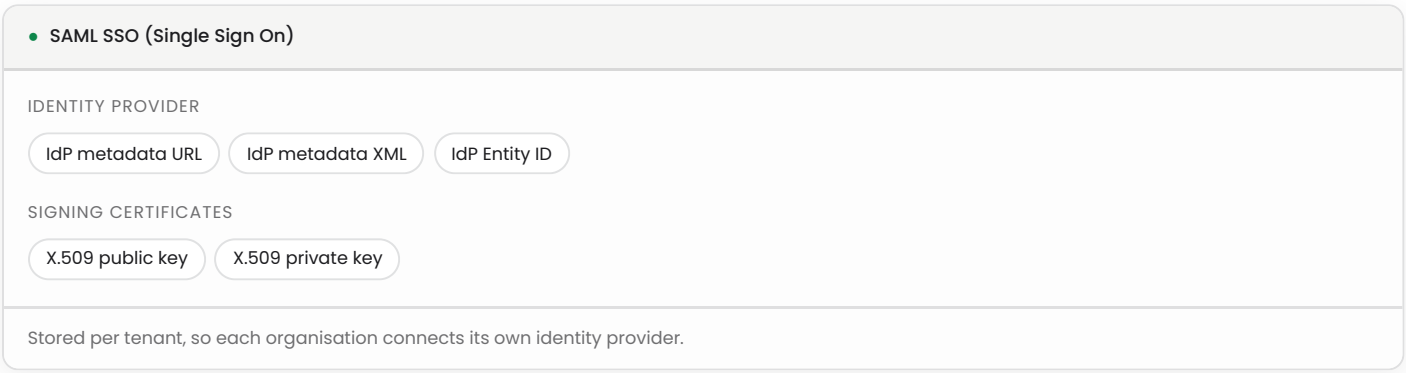
Who can sign in, how they prove who they are, and how long a session can stay open.

SAML Single Sign-On (SSO)

Users sign in with their organisation's existing identity provider instead of a separate platform password. Joiners, leavers and password rules stay in one place, the corporate directory.

- Admins connect the identity provider from a configuration page by entering its **metadata (URL or XML)** and **IdP Entity ID**.
- **X.509 certificates** (public and private key) are stored per tenant to sign and verify SAML messages.
- Users sign in from an SSO login link, and the identity provider's SAML response logs them straight in.

Configure in **Admin → Security Settings → SAML SSO (Single Sign On)**

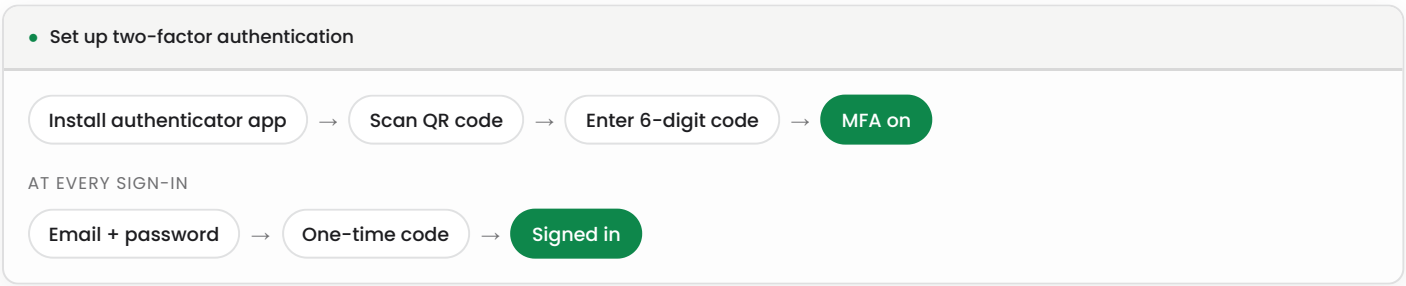


Multi-Factor Authentication (MFA)

A second factor on top of the password: a time-based one-time code from an authenticator app on the user's phone. A stolen password alone no longer gets anyone in.

- Each user sets up MFA from their **Profile** in two steps: install an authenticator app, then scan a QR code and enter the code to confirm.
- Each user's MFA secret is **encrypted at rest** with a dedicated encryption key.
- If a user loses their phone, an admin can **turn off MFA for that user** from the Users page so they can set it up again.

Users set it up in **Profile** · admins reset it in **Admin → Users**

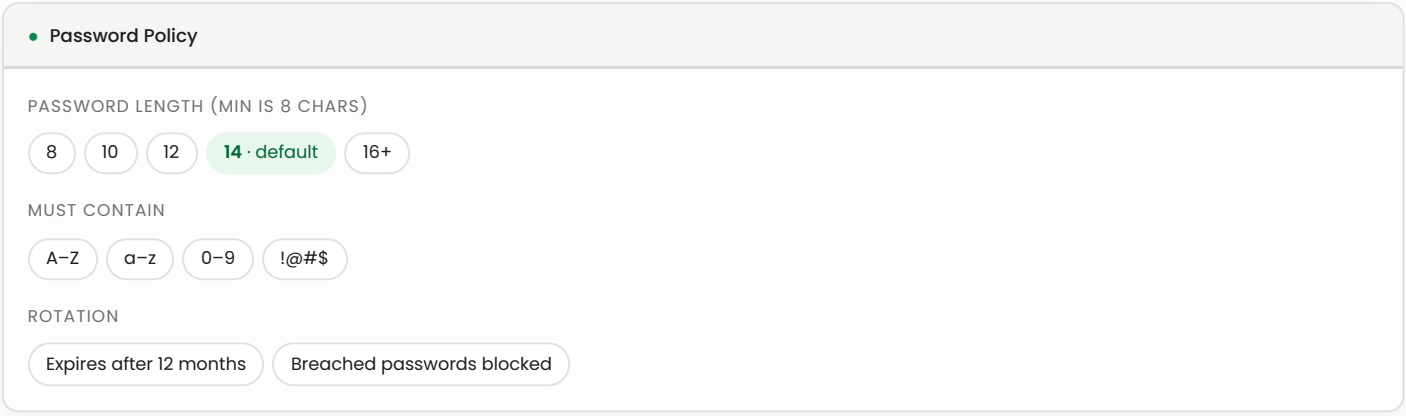


Password policy

When the policy is on, every password has to meet a minimum length and complexity rules, and passwords expire on a fixed cycle.

- **Minimum length** is set by the admin. It can't go below 8 characters and defaults to **14**. The maximum is 72.
- **Complexity:** at least one uppercase letter, one lowercase letter, one number and one symbol.
- **Expiry:** passwords must be changed every **12 months**.
- **Breached-password check:** passwords that appear in known data breaches (the *Have I Been Pwned* database) are rejected with *"This password has been previously exposed in N known data breaches."*

Configure in **Admin → Security Settings → Password Policy**

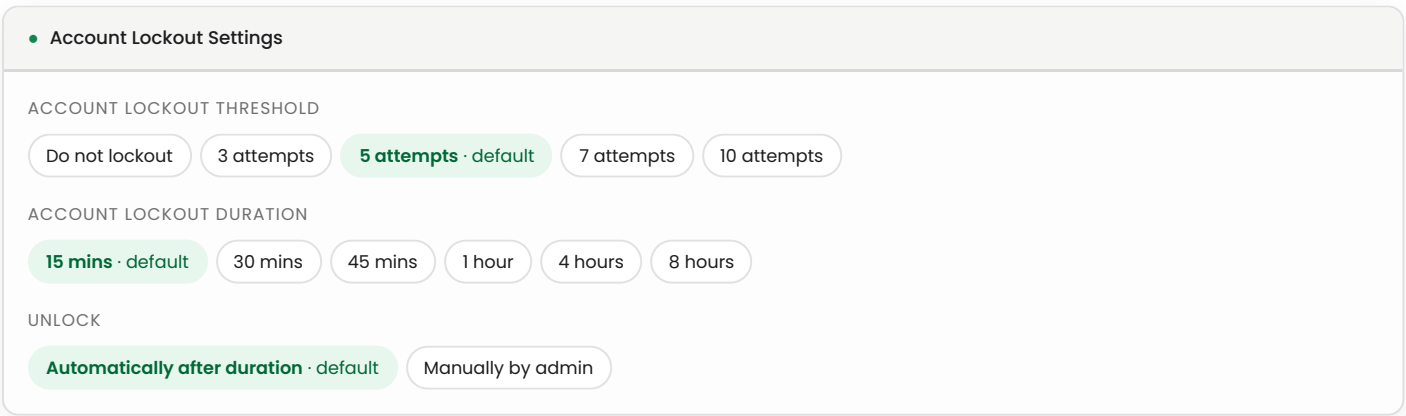


Account lockout policy

Stops password-guessing attacks. After a set number of failed sign-in attempts the account locks, either for a set time or until an admin unlocks it.

- **Threshold:** 3, 5, 7 or 10 failed attempts, or never lock.
- **Duration:** from 15 minutes up to 8 hours. The account unlocks on its own when the time is up.
- **Manual unlock:** alternatively, locked accounts stay locked until an administrator unlocks them.

Configure in **Admin → Security Settings → Account Lockout Settings**



Session timeout & single active session

Inactive sessions end on their own, so a browser left open on a shared or unattended computer doesn't stay signed in.

- **Inactivity timeout** from 15 minutes to 4 hours. The default is **1 hour**.
- **One active session per user:** signing in somewhere new ends the user's previous session.

Configure in **Admin → Security Settings → Session Timeout Settings**

- Session Timeout Settings

BROWSER SESSIONS WILL BE TIMED OUT AFTER

15 mins | 30 mins | **1 hour** · default | 2 hours | 3 hours | 4 hours

Account confirmation expiry

New users confirm their account from an emailed link. Admins decide how long that link stays valid, so old invitations can't be used to take over an account.

- Set as a **number and period**. The default is **2 days**.
- The clock starts when the account is created or when the confirmation email is resent.

Configure in **Admin → Security Settings → User Accounts Confirmation Expiry Time**

- User Accounts Confirmation Expiry Time

NUMBER · PERIOD

2 days · default

"The confirmation link sent to the user will expire within 2 days from the date the account is created or when the confirmation instructions were resent."

Network & data protection

Where the platform can be reached from, what users agree to when they sign in, and how files and credentials are protected.

Network settings: whitelisted IP addresses

Limit access to the organisation's own networks, such as offices and the corporate VPN. Requests from anywhere else get a **403 Forbidden** page before any data loads.

- Admins add one or more **IP ranges**, each with a "from" and a "to" address.
- The check runs on every request, not only at sign-in.

Configure in **Admin → Security Settings → Network Settings (Whitelisted IP Addresses)**

- Network Settings (example ranges)

RANGE 1 · HEAD OFFICE

203.0.113.0 → 203.0.113.255

RANGE 2 · VPN

198.51.100.10 → 198.51.100.20

Example addresses only. Any request from outside these ranges gets a 403.

Security responsibilities (logon banner)

A notice shown when users sign in, reminding them of their obligations: acceptable use, confidentiality, monitoring. It's a common requirement in government and enterprise security frameworks.

- Written in a **rich-text editor**, so it can include headings, lists and links.
- Each organisation writes its own wording.

Configure in **Admin → Security Settings → Configure Security Responsibilities Banner**

- Security Responsibilities Banner

Authorised use only. This system holds personal information. Activity is logged and monitored. By continuing you agree to the organisation's acceptable use and privacy policies.

Example wording. Each organisation writes its own.

Built-in data protection

Antivirus scanning

Every upload is virus-scanned when it lands in storage. Nobody can download an infected attachment or photo, except admins when the tenant explicitly allows it.

Your own email gateway

Send system email through the organisation's own SMTP server (host, port, credentials, STARTTLS). The credentials are stored encrypted.

Encrypted secrets

MFA secrets and mail-server credentials are encrypted at rest. Passwords and one-time codes are removed from application logs.

Hardened platform

Strict HTTP security headers are set on every response, and dependencies with known vulnerabilities are patched routinely.

Audit & compliance

Evidence for reviews, investigations and auditors: who signed in, what they did, and where data went.

User activity logs

The platform records user actions and saves them to each tenant's activity log in the background, in regular batches, so normal use doesn't slow down.

- **Users** can see their own activity.
- Roles with the **"View all activity logs"** permission can see everyone's.

- Who can see activity logs

ANY USER

Own activity · default

ROLE WITH "VIEW ALL ACTIVITY LOGS"

All users' activity

Sign-in tracking

For every user, the platform records how many times they've signed in, plus the time and IP address of their current and previous sign-ins.

Bulk export audit trail

Every bulk export of candidate records is logged, so it's clear who took data out of the system, and when.

Soft delete for attachments

Deleted attachments are kept rather than erased, so records can be recovered and reviewed later.

✅ **Built for compliance requirements:** these controls were built together as one programme of security requirements, so organisations bound by government or enterprise security frameworks can switch on everything they need in one go.

Where to configure

Each control is switched on per customer. Once it is on, the matching option appears under **Admin → Security Settings**, and the card hides itself when nothing is enabled.

Capability	Admin location	Default when enabled
IDENTITY & ACCESS		
SAML SSO	Security Settings → SAML SSO	No identity provider connected
MFA	User Profile · Admin → Users	Each user sets it up
Password policy	Security Settings → Password Policy	Minimum 14 characters, complexity rules, 12-month expiry
Breached-password check	Always on once enabled	Blocks known-breached passwords
Account lockout	Security Settings → Account Lockout Settings	5 attempts, 15-minute lock
Session timeout	Security Settings → Session Timeout Settings	1 hour
Confirmation expiry	Security Settings → User Accounts Confirmation Expiry Time	2 days
NETWORK & DATA PROTECTION		
IP whitelisting	Security Settings → Network Settings	No ranges set
Logon banner	Security Settings → Security Responsibilities Banner	Blank, organisation writes it
Infected-file download (admins)	Flag only	Infected files blocked for everyone
Custom email gateway	Admin → Communication	Platform mail server
AUDIT & COMPLIANCE		
User activity logs	User record → Activity logs	Own logs only, plus anyone with "View all" permission

⚙️ **Controls are enabled by ReadyTech.** An organisation asks for a control to be enabled, and its own admins then configure it.

Summary

What the platform offers for security and compliance, at a glance.

Capability	What it delivers
SAML SSO	Sign in with the organisation's identity provider. Access is managed centrally and switched off when a staff member leaves.
Multi-factor authentication	Authenticator-app one-time codes on top of the password, with an admin reset for lost devices.
Password policy	Configurable minimum length, complexity rules, 12-month expiry and a check against known-breached passwords.
Account lockout	Locks the account after 3–10 failed attempts, for a set time or until an admin unlocks it.
Session controls	Inactivity timeout from 15 minutes to 4 hours, and one active session per user.
Confirmation expiry	Account invitation links expire after a time the admin sets.
IP whitelisting	Access only from approved networks. Everyone else gets a 403.
Logon banner	Security responsibilities shown at sign-in, in the organisation's own words.
Antivirus & encryption	Every upload scanned, infected files blocked, secrets encrypted at rest, and mail sent through the organisation's own gateway.
Activity & audit logs	User activity logs, sign-in tracking, a bulk-export audit trail and soft-deleted attachments.
Controlled rollout	Each control is switched on per tenant, so organisations adopt what their framework requires.

🚀 **The takeaway:** the platform gives each organisation the access controls, protections and audit evidence it needs to meet its security obligations, and the organisation configures them itself without waiting on a release.